

Preparing before the incident

Provisioning access, deploying tools, minimising blast radius, and what Shield Advanced actually buys you.

Every minute spent getting permission during an incident is a minute the attacker still has.

Provisioning access before you need it

- ◆ A **pre-created incident response role in every account**, deployed by StackSets so new accounts get it automatically.
- ◆ Its trust policy allows only the **security account** to assume it, and requires **MFA**.
- ◆ Responders hold no standing permissions in workload accounts. They assume the role when needed, and every assumption is in CloudTrail.
- ◆ Scope it with a **permissions boundary**. Investigation and containment, not unrestricted administration.
- ◆ Short session durations. A long-lived responder session is a credential worth stealing.

ON THE EXAM

The role exists before the incident. What happens during the incident is an AssumeRole call, not a change request.

Protecting the thing that protects you

- ◆ A compromised admin can **delete the IR role** before you use it. That is a real attacker move.
- ◆ Defend it with an **SCP** denying modification or deletion, except by the security account.
- ◆ The same shape protects **CloudTrail, Config, GuardDuty and the log archive bucket**.
- ◆ **Break-glass**: a separate rarely-used path, alarmed on use, never used routinely.
- ◆ An unmonitored break-glass credential is just an unmonitored administrator.

ON THE EXAM

Protecting security controls from your own administrators is the SCP's best use case.

Deploying the tools in advance

- ◆ **SSM Agent and an instance profile everywhere.** Without them: no Session Manager, no Automation, no collection.
- ◆ Bake it into the **AMI** with EC2 Image Builder, not onto a host you already distrust.
- ◆ **GuardDuty Runtime Monitoring** and the CloudWatch agent, running before you need them.
- ◆ A **forensic account** with its own VPC and keys, and no trust back to workload accounts.
- ◆ Installing anything on a compromised host changes it, and the attacker may see you arrive.

ON THE EXAM

Touching a compromised host to install tooling destroys evidence and tips off the intruder.

Minimising blast radius

- ◆ **The account is the strongest boundary AWS offers.** Separate production, non-production and security.
- ◆ **One role per workload**, not one shared by fifty. A shared role reaches everything it can touch.
- ◆ Scope to the resources that workload uses. Prefer **short-lived credentials** over access keys.
- ◆ **Segment the network** – isolated subnets, security groups referencing security groups.
- ◆ **Tag consistently.** Tags answer 'what else does this touch' in seconds, not hours.

ON THE EXAM

Blast radius is decided at design time. During an incident you only discover how large it is.

Shield Standard and Shield Advanced

	STANDARD	ADVANCED
Cost	Included, no charge	Paid subscription, annual commitment
Layers	Network and transport, layers 3 and 4	Adds application layer, layer 7
Visibility	None into events	Detailed event visibility and metrics
Shield Response Team	No	Yes, with Business or Enterprise Support
Cost protection	No	Service credits for DDoS-driven spikes
Protected types	Everything, automatically	EIP, ELB, CloudFront, Route 53 zones, Global Accelerator

ON THE EXAM

You already have Shield Standard and cannot turn it off. Every Shield question is really about whether Advanced is justified.

Health-based detection and proactive engagement

- ◆ **Associate a Route 53 health check** with a protected resource to inform detection.
- ◆ It **reduces false positives** and speeds mitigation – a spike versus a spike that is hurting you.
- ◆ Works for every protected type **except Route 53 hosted zones**.
- ◆ **Proactive engagement**: the SRT contacts **you** when a health check goes unhealthy during an event.
- ◆ **No health check, no proactive engagement**. Up to ten contacts.

ON THE EXAM

Health check, then health-based detection, then proactive engagement. That chain is the exam question.

Shield Advanced: the honest version

- ◆ Automatic application layer DDoS mitigation ends 1 January 2027. The WAF Anti-DDoS managed rule group replaces it.
- ◆ `AWSManagedRulesAntiDDoSRuleSet` launched June 2025 and mitigates layer 7 within seconds.
- ◆ The SRT needs **Business or Enterprise Support**. Shield Advanced alone does not get you the team.
- ◆ Layer 7 is included up to 50 billion WAF requests per month, chargeable beyond.
- ◆ **Protection groups** treat several resources as one unit. **Firewall Manager** applies it org-wide.

ON THE EXAM

A course recorded in 2024 teaches automatic layer 7 mitigation as current. It has an end date now.

During a compromise in a workload account, the security team could not act for four hours. Responders had no permissions in that account, and the account owner had to raise a change request, get approval, and manually create an IAM role before anything could begin. The company has 180 accounts in AWS Organizations and creates new ones weekly. The CISO wants responders able to act immediately in any account, with no standing permissions in workload accounts and a record of every action taken.

What should the company implement?

- ☐ A Store root user credentials for each account in a shared password manager the security team can access
- ☐ B Grant the security team's IAM Identity Center users an AdministratorAccess permission set in every account
- ☐ C Deploy an IR role to every account by StackSet, trusting only the security account and requiring MFA
- ☐ D Create an SCP that allows the security team to bypass account permissions during an incident

◆ PAUSE AND DECIDE

What should the company implement?

A Root credentials in a shared password manager
Shared credentials with no individual attribution, on the one identity that cannot be constrained by an SCP. It fails the audit requirement outright.

C IR role per account via StackSet, security-account trust, MFA
Correct. Pre-created so there is nothing to approve, no standing permission because it must be assumed, and every AssumeRole is in CloudTrail.

B AdministratorAccess permission set everywhere
Fast, and it is standing permission in every workload account – exactly what the CISO ruled out. It also grants far more than containment needs.

D An SCP letting the team bypass account permissions
Not what SCPs do. They set a maximum permission boundary and can only restrict. No SCP has ever granted anyone anything.

THE SIGNAL

Three requirements: immediate, no standing permission, fully recorded. Only a pre-created assumable role satisfies all three at once.

A ticketing company runs its site behind CloudFront and an Application Load Balancer. It subscribes to Shield Advanced and has Enterprise Support. During a recent attack the site degraded badly for 40 minutes before anyone noticed, and the team contacted the SRT themselves once they had.

The security manager wants the SRT to reach out to the on-call team as soon as an attack starts affecting the application, rather than waiting for the company to notice and open a case.

What must the company configure?

- ☐ A Associate Route 53 health checks with the protected resources, then enable proactive engagement with contacts
- ☐ B Upgrade the support plan, since proactive engagement requires Enterprise Support
- ☐ C Enable automatic application layer DDoS mitigation on the CloudFront distribution
- ☐ D Create a CloudWatch alarm on the DDoSDetected metric with an SNS topic subscribed by the SRT

What must the company configure?

- A

 Route 53 health checks, then enable proactive engagement
Correct. Proactive engagement is only available for protected resources with an associated health check – the SRT uses its state to decide whether an event qualifies.
- B

 Upgrade the support plan
They already have Enterprise Support, which the scenario states. SRT access needs Business or Enterprise, so this requirement is already met.
- C

 Enable automatic application layer DDoS mitigation
A real feature that mitigates attacks automatically. It does not cause anyone to telephone your on-call team, and it is being retired on 1 January 2027.
- D

 CloudWatch alarm with the SRT subscribed to an SNS topic
You cannot subscribe the SRT to your SNS topic. Proactive engagement is a configured Shield Advanced feature, not a notification you wire up.

THE SIGNAL

The dependency is the answer: health check, then health-based detection, then proactive engagement. Skip the first and the third is unavailable.

A media company's DDoS runbook, written in 2024, depends entirely on Shield Advanced automatic application layer mitigation. The runbook states that no AWS WAF rules are needed because Shield handles layer 7 automatically.

The security architect is reviewing the runbook in late 2026 as part of an annual audit and must recommend what changes, if any, are needed for the next twelve months.

What should the architect recommend?

- A No change. Automatic application layer mitigation remains the recommended approach
- B Replace Shield Advanced with AWS WAF rate-based rules, since Shield Advanced is being retired
- C Add Shield Standard, which now provides the layer 7 protection Shield Advanced used to
- D Adopt the AWS WAF Anti-DDoS managed rule group before automatic mitigation ends on 1 January 2027

◆ PAUSE AND DECIDE

What should the architect recommend?

- A

 No change needed
True when the runbook was written, false now. Automatic application layer mitigation has an announced end date inside the review period.
- B

 Replace Shield Advanced entirely
Overreads the change. One feature is being retired, not the service. Shield Advanced keeps the SRT, cost protection, event visibility and layer 3 and 4 protection.
- C

 Shield Standard now provides layer 7
Fabricated. Shield Standard has always covered layers 3 and 4 only, and nothing about this change alters that.
- D

 Adopt the WAF Anti-DDoS managed rule group before 1 January 2027
Correct. AWSManagedRulesAntiDDoSRuleSet is the named replacement, it launched in June 2025, and the deadline falls inside the twelve-month window.

THE SIGNAL

The review window and the retirement date overlap. Whenever a scenario gives you a date, check what changes inside it.

A logistics platform runs 200 Lambda functions. To simplify deployment, all of them share one execution role granting read and write access to every DynamoDB table and every S3 bucket in the account.

A dependency confusion attack compromises one low-value reporting function. The attacker uses its credentials to read customer records from tables that function never touches. The post-incident review asks how to prevent recurrence.

What is the MOST effective change?

- ☐ A Enable GuardDuty Lambda Protection to detect malicious network activity from functions
- ☐ B Give each function its own execution role scoped to the resources it actually uses
- ☐ C Rotate the shared execution role's credentials on a daily schedule
- ☐ D Add a permissions boundary to the shared role limiting it to DynamoDB and S3

◆ PAUSE AND DECIDE

What is the MOST effective change?

A GuardDuty Lambda Protection

Detective, and worth having. It would tell you the reporting function was doing something odd. It would not have stopped the reads.

C Rotate the role's credentials daily

Role credentials are already short-lived and rotated automatically by STS. There is no long-lived secret here to rotate.

B One scoped execution role per function

Correct. The blast radius was defined by the shared role. Per-function roles mean compromising the reporting function reaches only reporting data.

D A permissions boundary on the shared role

Caps the role at DynamoDB and S3 – which is precisely what it already had, and precisely what was abused. It constrains nothing that matters.

THE SIGNAL

The vulnerability was the dependency. The damage was the shared role. Preventing recurrence of the damage means shrinking the role.

Five things to carry forward

- ◆ **Pre-created IR role, StackSet-deployed, security-account trust, MFA.**
- ◆ **An SCP restricts, never grants.** Any option describing an SCP granting access is wrong.
- ◆ **One role per workload.** A shared role makes blast radius equal everything it reaches.
- ◆ **Proactive engagement needs Route 53 health checks;** the SRT needs Business or Enterprise Support.
- ◆ **Shield Advanced automatic layer 7 mitigation ends 1 January 2027.**

ON THE EXAM

Next: testing the plan – Fault Injection Service, Resilience Hub, Application Recovery Controller.